The End of Anarchy? IoTマルウェア感染に利用されるHTTPエクスプロイトのライフサイクルの実態調査

九鬼 琉[1,a)]　佐々木 貴之[1]　Arwa Al Alsadi[2]　Carlos Gañán[1,2]　吉岡 克成[1]

概要：近年，Internet of Things（IoT）機器の脆弱性を標的とする攻撃が深刻化する一方，その被害を抑制するための対策も進められてきた．しかし，攻撃の開始から減少に至るまでのライフサイクル全体や，PoC の公開，マルウェアへの組み込み，セキュリティパッチの公開などのライフイベントが攻撃傾向に与える影響は十分に明らかでない．そこで本研究では，2019 年 7 月から 2024 年 8 月までにハニーポットで観測した HTTP リクエスト，収集したマルウェア検体，公開脆弱性情報を統合し，IoT エクスプロイトのライフサイクルを分析した．その結果，機器および脆弱性の年代に応じて攻撃傾向が異なることを確認した．また，PoC の公開直後に攻撃が開始される事例や，マルウェアへの組み込みやセキュリティパッチの公開などのライフイベントが攻撃の増減に与える影響を示した．さらに，CVE-2025 以降の CVE-ID が付与され，かつ悪用を観測した脆弱性では，NVD 公開から初回の攻撃観測までの期間が短縮傾向にあることを確認し，脆弱性開示後の迅速な対応の重要性が高まっていることを示した．

キーワード：ハニーポット，マルウェア，脆弱性

The End of Anarchy? Understanding the Life of HTTP Exploits Used in IoT Malware Infections

Ryu Kuki[1,a)]　Takayuki Sasaki[1]　Arwa Al Alsadi[2]　Carlos Gañán[1,2]　Katsunari Yoshioka[1]

Abstract: In recent years, attacks targeting vulnerabilities in Internet of Things (IoT) devices have become increasingly serious, while various security measures have been introduced to mitigate their impact. However, the overall life cycle of these attacks, from their onset to decline, and the effects of key life events, such as the release of proof-of-concept (PoC) code, weaponization in malware, and the release of security patches, on attack activity remain insufficiently understood. In this study, we integrate HTTP requests observed by honeypots from July 2019 to August 2024, collected malware samples, and publicly available vulnerability information to analyze the life cycle of IoT exploits. Our results reveal distinct attack trends across different generations of devices and vulnerabilities. We also identify cases in which attacks begin shortly after the release of PoC code and show how life events, including weaponization in malware and the release of security patches, are associated with increases and decreases in attack activity. Furthermore, for vulnerabilities assigned CVE IDs in 2025 or later, we observe a trend toward shorter delays between NVD publication and the first observed attack, highlighting the increasing importance of rapid defensive responses following NVD publication.

Keywords: Honeypot, Malware, Vulnerability

[1] 横浜国立大学
Yokohama National University
[2] デルフト工科大学
Delft University of Technology
[a)] kuki-ryu-dr@ynu.jp

本稿は，国際会議論文 [1] の主要な成果を要約し，あわせて追加の分析結果を示すものである．

© 2026 Information Processing Society of Japan

This paper is work in progress and not peer-reviewed.

1. はじめに

インターネットに露出したルータ，カメラ，NAS，NVR などの Internet of Things（IoT）機器は，脆弱性を悪用したマルウェア感染の主要な標的の一つである．これまで，IoT マルウェア検体の解析により，その感染過程や攻撃手法の実態，悪用される脆弱性の増加傾向が明らかにされてきた [2], [3]．また，Al Alsadi らは，約 17,000 件の IoT マルウェア検体を解析し，公開から 12 年が経過した脆弱性から最新の脆弱性まで合計 68 件が悪用されていること，および一度マルウェア検体に組み込まれたエクスプロイトは，その利用がほとんど中止されないことを明らかにした [4]．さらに同著者らは，攻撃者による脆弱性選択の要因を分析し，機器のインターネット露出状況，Proof of Concept（PoC）コードの有無，セキュリティパッチの提供状況および適用の複雑さなどが関与することを示した [5]．

一方，これらの既存研究は，主として悪用対象となる脆弱性の選択や攻撃規模に焦点を当てており，攻撃の開始からピークを経て減少に至るまでのエクスプロイトのライフサイクル全体の時系列的推移や，その攻撃規模および継続期間を左右する要因については，十分に明らかにされていない．さらに，既存研究の多くは，マルウェア検体に組み込まれたエクスプロイトを主な解析対象としているため，クラウド上の攻撃基盤等から直接実行されるエクスプロイトの実態を十分に捉えられていない．

そこで本研究では，以下の 2 つのリサーチクエスチョン（RQ）を設定する．**（RQ1）脆弱性の年代によって，攻撃傾向はどのように異なるか？（RQ2）IoT エクスプロイトのライフサイクルにはどのようなライフステージとライフイベントがあり，それらはどのように関係しているか？**

RQ1 に答えるため，2008 年から 2024 年までに公開された IoT 脆弱性を対象として，エクスプロイトの長期的な観測動向を比較し，脆弱性の年代に応じて三つの年代群に大別した．古い脆弱性（2012 年以前）に対する攻撃は，現在では散発的にしか観測されない．これは，製品の寿命に伴う稼働機器数の減少により，エクスプロイトの有効性が低下したためと考えられる．これに対し，2013 年から 2018 年までの脆弱性では，ファームウェアが更新されないまま脆弱な状態で利用され，脆弱な機器やマルウェア感染機器が残存している可能性があるため，大規模な攻撃が継続的に観測されている．一方，新しい脆弱性（2019 年以降）では，自動ファームウェア更新をはじめとするセキュリティ対策が広く導入されたことにより，攻撃が短期間で減少する傾向がみられる．これらの結果は，これまで行われてきた機器メーカーによる様々なセキュリティ対策 [6], [7] が一定の改善効果，すなわち「End of Anarchy」をもたらしつつあることを示唆する．

RQ2 に答えるため，ハニーポットの設置後に公開された IoT 脆弱性を対象として，エクスプロイトのライフサイクルを攻撃開始，ピーク，減少の三つのライフステージに区分し，脆弱性の開示，PoC の公開，マルウェアへの組み込み，セキュリティパッチの公開といったライフイベントとの関係を分析した．攻撃の開始段階では，PoC の公開から 24 時間以内に初回の攻撃が観測される事例を確認した．攻撃のピーク段階では，エクスプロイトがマルウェアに組み込まれることで攻撃規模が増大する傾向を確認した一方，マルウェアに組み込まれないまま，少数のクラウド上のホストから大規模に悪用される事例も確認した．攻撃の減少段階では，セキュリティパッチの公開や自動ファームウェア更新機能が攻撃の減少に寄与する一方，マルウェアへの組み込みが攻撃の減少を遅らせる傾向にあることを確認した．

加えて，国際会議論文 [1] の分析期間以降に得られた追加の観測データを用いて，2025 年および 2026 年に公開された IoT 脆弱性に対する攻撃の傾向を分析した．その結果，NVD での公開日から我々のハニーポットで悪用を初めて観測するまでの期間が，2024 年以前に公開された脆弱性と比較して短くなる傾向にあることを確認した．

本論文の貢献は以下の通りである．

- 5 年間のハニーポット観測，マルウェア解析，ならびにセキュリティアドバイザリおよび機器マニュアルを含む公開情報を統合し，IoT エクスプロイトのライフサイクルを明らかにした．
- セキュリティ対策を備えていない古い機器と比較して，セキュリティ対策機能を備える新しい機器を標的とするエクスプロイトの継続期間が短縮傾向にあることを明らかにした．
- IoT エクスプロイトを攻撃開始，攻撃のピーク，攻撃減少の三つのライフステージに分けて定義し，PoC 公開，マルウェアへの組み込み，セキュリティパッチの公開といった主要なライフイベントが各段階に与える影響を分析した．

2. IoT エクスプロイトのライフサイクル

2.1 エクスプロイトのライフステージ

本研究では，エクスプロイトのライフサイクルを構成する三つのライフステージとして，攻撃の開始，攻撃のピーク，攻撃の減少を定義する．具体的には，各エクスプロイトが我々のハニーポット群で初めて観測された時点を攻撃の開始，観測期間中に観測件数が最大となった日を攻撃のピーク，日次の観測件数がピーク時の 50%および 10%を最後に下回った日を攻撃の減少と定義した．

2.2 エクスプロイトのライフイベント

本研究では，エクスプロイトのライフサイクルに影響す

© 2026 Information Processing Society of Japan

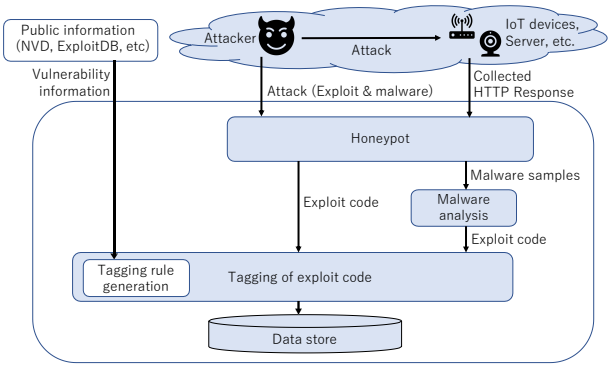


図 1 攻撃観測・解析システム

る主要なライフイベントとして，脆弱性の開示，PoC の公開，マルウェアへの組み込み，セキュリティパッチの公開を定義する．それぞれ具体的には，NVD における当該 CVE-ID の公開日，GitHub・Exploit-DB・Packet Storm における当該 CVE-ID の PoC 公開日，我々が収集したマルウェア検体に当該エクスプロイトを初めて確認した日，当該機器の製品ベンダまたは第三者が公開したセキュリティアドバイザリを根拠としたセキュリティパッチの公開日を基準とした．

3. データ収集

3.1 ハニーポットを用いた攻撃観測

本研究では，ハニーポット，マルウェア解析コンポーネント，攻撃タグ付けコンポーネントから構成される攻撃観測・解析システムを実装した（図 1）．ハニーポットが収集したマルウェア検体をマルウェア解析コンポーネントで解析し，表層解析によってマルウェア検体に含まれるエクスプロイトを特定する．マルウェア解析から得たエクスプロイト情報とハニーポットの観測結果をタグ付けコンポーネントへ渡し，既知の攻撃に対応する CVE-ID を付与し，CVE-ID が割り当てられていない場合には対象機器情報を付与する．

3.1.1 ハニーポットによる攻撃観測

我々は，インターネット上の IoT 機器の応答を収集することにより模倣対象の機器を拡張できる適応型 HTTP ハニーポット X-POT[8] を採用し，2019 年 7 月 21 日から 2024 年 8 月 14 日までの約 5 年間に渡り，著者らおよび共同研究先の大学ならびにクラウドプロバイダ上に，複数地域へ分散して 22 個のハニーポットインスタンスを配置した．配置したインスタンスの一覧は付録 A.3 の表 A·1 に記載する．

3.1.2 攻撃観測ログに対する CVE-ID 情報のタグ付け

はじめに，スキャンなどの直接的な攻撃ではない通信を除外し，マルウェア感染に繋がる深刻なエクスプロイトのみを抽出するため，`wget` や `curl` などのダウンロードコマンドおよびマルウェア検体 URL を含む HTTP リクエストを分析対象とした．本手法は誤検知を大幅に低減する一方で，偽陰性を生じさせる可能性があるため，その影響については第 5.3 節で議論する．

次に，抽出した攻撃に対し，リクエストパスや特徴的なパラメータ名などに基づく独自のタグ付けルールを適用し，各攻撃観測ログに対して CVE-ID や対象機器種別を付与した．既存ルールに一致しない新たな攻撃については，特徴文字列の抽出と脆弱性データベース検索を経て新規ルールを作成した．作成したルールは，それぞれ 5 年および 20 年の経験を持つ 2 名のセキュリティ研究者が相互検証したうえで，過去に収集した攻撃データを含むデータセット全体へ適用した．タグ付けルールの記載例，CVE 対応付けの判定方法，および検証手順の詳細は付録 A.3.2 に示す．

3.1.3 マルウェア解析

収集したマルウェア検体に対して表層解析を実施し，マルウェア検体に含まれるエクスプロイトを特定した．具体的には，`strings` コマンドを用いてサンプルから可読文字列を抽出し，これをタグ付けルールのシグネチャと照合することで，マルウェア検体に含まれるエクスプロイトを特定した．なお，パッキングされたサンプルのアンパックや完全なリバースエンジニアリングは実施していないため，難読化または暗号化された一部のエクスプロイトを見落とす可能性がある（第 5.3 節）．

3.2 公開脆弱性・エクスプロイト情報

エクスプロイトのライフイベントを特定する参照情報として，分析時点である 2024 年 8 月 14 日までに公開された脆弱性およびエクスプロイトの情報を収集した．脆弱性情報は，NVD，CNVD，および Vulners から取得した．加えて製品ベンダまたは第三者が公開したセキュリティアドバイザリ 86 件から各脆弱性に対するセキュリティパッチの提供有無と公開日を，機器のユーザーマニュアルから自動ファームウェア更新機能の有無を人手で確認した．

PoC の公開状況を収集するため，Exploit-DB，GitHub，および Packet Storm を対象に，当該 CVE-ID を含む PoC コードを収集した．これら三つの情報源のうち少なくとも一つに，当該 CVE-ID が明示された PoC コードが公開されている場合に PoC を「提供あり」と判定し，各情報源のうち最も早い公開日を記録した．また，攻撃元 IP アドレスがホスティングサービスまたは ISP のいずれに属するかの判定には IPinfo を用いた．各情報源の収集件数などの詳細は付録 A.4 に示す．

4. 分析結果

4.1 ハニーポットによる観測結果の概要

表 1 にハニーポットによる観測の統計を示す．2019 年 7 月 21 日から 2024 年 8 月 14 日までの約 5 年間に，195,452 個の IP アドレスから 3,757,534 件の攻撃セッションを観測

© 2026 Information Processing Society of Japan

表 1 ハニーポット観測データの概要

観測期間：2019 年 7 月 21 日から 2024 年 8 月 14 日

全 HTTP セッション	226,720,844
攻撃 HTTP セッション	3,757,534
攻撃元 IPv4 アドレス	195,452
収集マルウェア検体（ハッシュ値ユニーク）	35,826

表 2 観測した IoT エクスプロイトにおけるライフイベント状況

	ルータ	ルータ以外	合計
観測済 IoT エクスプロイト	63	64	127
CVE-ID 採番済	51	43	**94**
うちハニーポット配置後に開示	27	25	**52**
セキュリティパッチ提供あり	24	31	55
PoC 公開済み	26	23	49
マルウェアへの組み込みを確認	24	9	33

し，35,826 件のマルウェア検体を収集した．

また，これらの観測データに対し第 3.1 節で述べた手法でエクスプロイトのタグ付けを行った結果，IoT 機器を標的とする 127 種類のエクスプロイトを確認し，そのうち 94 件について対応する CVE-ID を特定できた．なお，対応する CVE-ID が特定できなかった 33 件のエクスプロイトについては脆弱性の開示日などのライフイベントを正確に特定することが困難であるため，以後の分析対象から除外した．

各エクスプロイトにおける主要なライフイベントの状況を表 2 に示す．94 件のエクスプロイトのうち，セキュリティパッチが提供されていたのは 55 件，PoC が公開されていたのは 49 件，マルウェアへの組み込みが確認されたのは 33 件だった．また，7 件のエクスプロイトについて，影響を受ける主要な機器がファームウェアの自動更新機能を備えていた．

IoT 機器の種別ごとにみると，ルータを標的とするエクスプロイトとそれ以外の IoT 機器を標的とするエクスプロイトの間に大きな傾向の差は見られなかったが，マルウェアへの組み込みが確認された割合についてはルータを標的とするエクスプロイトの方が高かった．具体的には，マルウェアへの組み込みが確認された 33 件のうち，24 件がルータ，9 件がルータ以外を標的としていた．

4.2 脆弱性の年代ごとの長期的な攻撃傾向

本節では，CVE-2008 から CVE-2024 までの 94 件の脆弱性を標的とするエクスプロイトをその年代別に分析し，近年のさまざまなセキュリティ対策による改善の兆候が存在するかを調査する．

図 2 に，94 件の IoT エクスプロイトそれぞれに対する約 5 年間にわたる攻撃件数の時間的推移を示す．同図から，IoT エクスプロイトは攻撃傾向の特徴に応じて，以下の三つの年代に大きく分類できる．

古い脆弱性（2012 年以前）：これらの古い脆弱性に対する攻撃は，現在では少数が散発的に観測されるにとどまり，大規模な攻撃はほとんど確認されていない．この一因として，製品寿命の経過に伴い，当該脆弱性の影響を受ける稼働中の機器が減少したことで，攻撃対象となり得る機器が限定され，攻撃活動も低調になった可能性が考えられる．

中期の脆弱性（2013 年から 2018 年）：これらの中期の脆弱性に対する攻撃は，現在も大規模な攻撃が継続的に観測されている．その一因として，当該脆弱性の影響を受ける機器が，セキュリティパッチの適用などの適切な対策が講じられないまま，現在も運用され続けていることが考えられる．

新しい脆弱性（2019 年以降）：これらの新しい脆弱性に対する攻撃は，脆弱性の公開直後に大規模な攻撃が発生する場合があるものの，中期の脆弱性と比較して短期間で減少する傾向がみられる．その一因として，多くの新しい IoT 機器が，セキュリティパッチを迅速に適用する自動ファームウェア更新などのセキュリティ機能を備えるようになったことが挙げられる．本研究では，機器マニュアルを参照してファームウェア自動更新機能の有無を調査しており，その影響について第 4.3.3 節で分析する．これらの傾向は，これまで行われてきた機器メーカーによる様々なセキュリティ対策 [6], [7] が肯定的な効果，すなわち「End of Anarchy」をもたらしつつあることを示唆する．

4.3 IoT エクスプロイトのライフサイクルの分析

本節では，エクスプロイトのライフサイクルを構成する三つのライフステージおよび主要なライフイベントを一貫して分析するため，表 2 に示すエクスプロイトのうち，ハニーポットの設置後に新たに CVE-ID が公開された 52 件を分析対象とする．

分析結果の全体像として，図 3 に，NVD 公開日を基準日（0 日）とした各ライフイベントおよびライフステージの発生・到達日数の分布を示す．セキュリティパッチは中央値-9 日で脆弱性の公開前に提供される場合が多い一方，PoC は中央値 3 日で公開後数日以内に出現する傾向がみられた．攻撃が公開直後に開始される事例もみられたが，初回攻撃観測までの日数の中央値は 72 日であった．最も早い事例では，NVD 公開の 1 日後にマルウェアへの組み込みを観測した一方，NVD 公開前にマルウェアに組み込まれていた事例は確認されなかった．

攻撃規模は，NVD 公開から中央値で 209 日後にピークに達し，405 日後にはピーク時の 50%，432 日後には 10% まで減少した．また，ルータを標的とするエクスプロイトは，ルータ以外を標的とするエクスプロイトよりも，攻撃が長期化する傾向がみられた．この結果は，ルータを標的とするエクスプロイトほどマルウェアに組み込まれやすいという第 4.1 節の分析結果と整合する．以下では，各ライ

© 2026 Information Processing Society of Japan

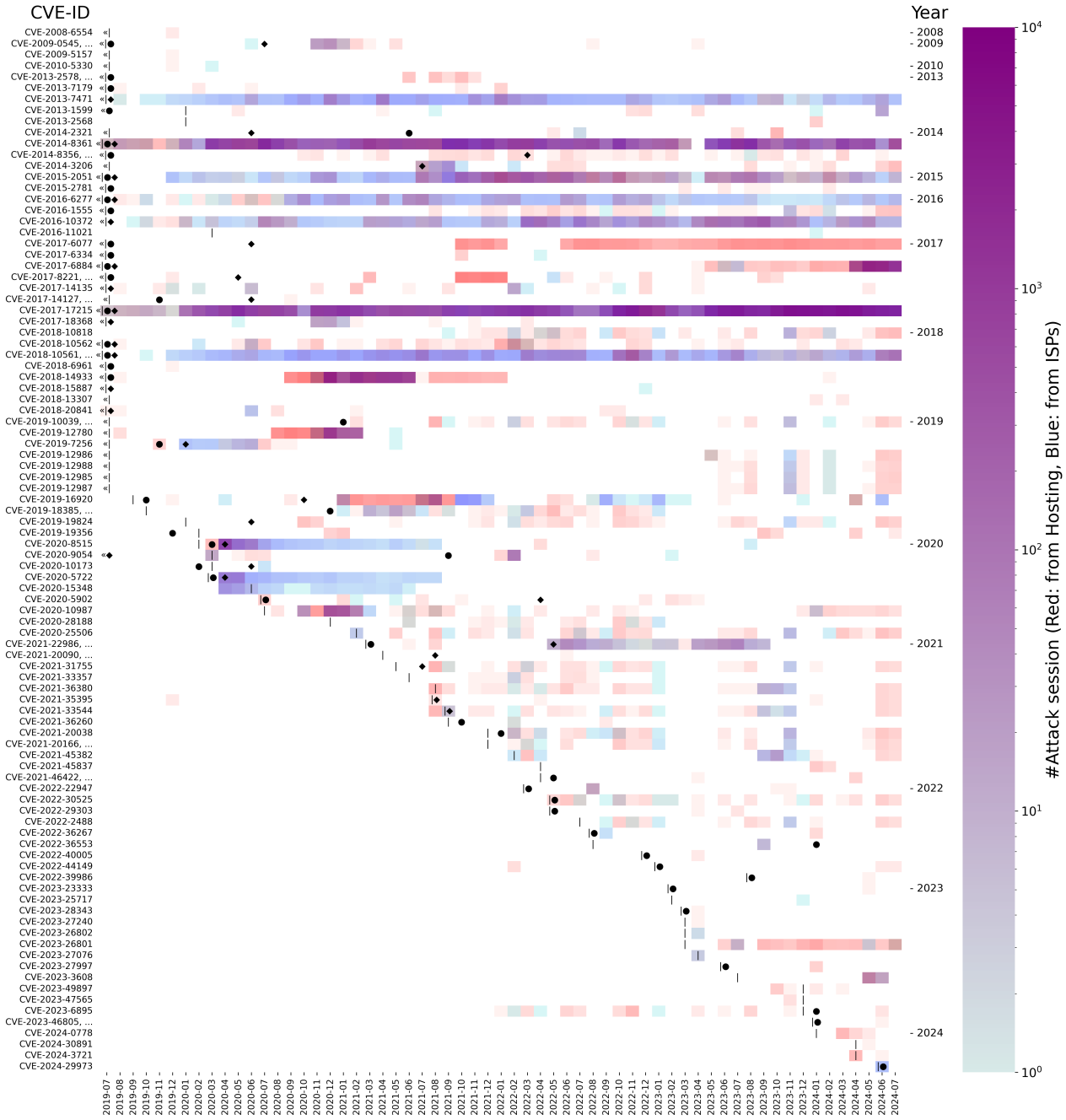


図 2 ハニーポットで観測されたエクスプロイト別の時系列概要
色の濃さは攻撃リクエスト数を表し，赤色はホスティングサービスからの攻撃，青色は ISP からの攻撃を示す．
| 印は NVD 公開日，● 印は PoC 公開日，♦ 印はエクスプロイトがマルウェア検体に初めて組み込まれた日を示す．

フステージについて詳細に分析する．

4.3.1 攻撃開始

初回攻撃の送信元．エクスプロイトのライフサイクルには，攻撃者がホスティングサービス上に構築したインフラから攻撃を開始し，その後エクスプロイトがマルウェアに組み込まれる経路と，攻撃開始時点ですでにマルウェアに組み込まれており，感染した消費者向け IoT 機器が接続する ISP ネットワークから攻撃が送信される経路の二つが考えられる．初回攻撃の送信元について，攻撃元 IP アドレスが属する AS（Autonomous System）に基づいて分析した結果，71.2%がホスティングサービスから送信されていた．この結果は，多くのエクスプロイトのライフサイクルが，感染機器から送信されるマルウェアによる攻撃ではなく，ホスティングサービス上のサーバから開始されることを示唆する．

PoC 公開から攻撃開始までの期間．ハニーポットで観測した 52 件のエクスプロイトが標的とする脆弱性について，第 3.2 節に示した方法により PoC の公開状況を調査した結果，26 件の脆弱性について PoC の存在を確認した．ただし，他の Web サイトで公開された PoC や，CVE-ID

© 2026 Information Processing Society of Japan

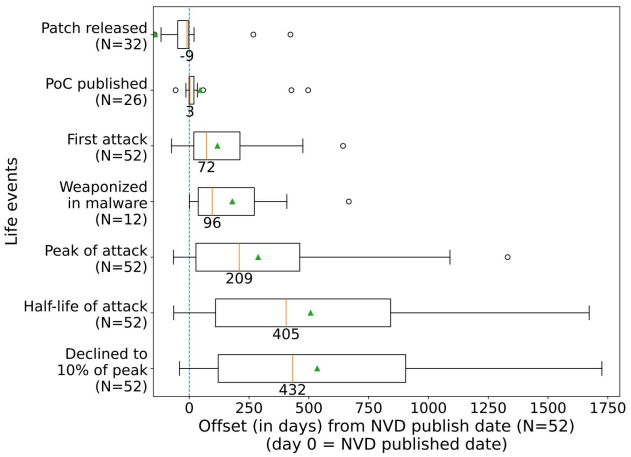


図 3　脆弱性の開示日を基準としたライフイベントの時差

を明示せずに公開された PoC については収集できていない可能性がある（第 5.3 節）．

PoC が公開されると，攻撃者はそのコードを利用して脆弱性を悪用する攻撃を比較的容易かつ迅速に実行できる可能性がある．既存研究 [5] でも，PoC の存在によりエクスプロイトコードをマルウェアへ組み込みやすくなる可能性が指摘されている．そこで，PoC の存在を確認した 26 件について，PoC 公開日から初回攻撃観測日までの期間を調査した（付録 A.6 の図 A·7）．その結果，PoC 公開から初回攻撃観測までの日数の中央値は 60 日であった．一方，4 件では PoC 公開から 24 時間以内に初回攻撃が観測された．

付録 A.5 の図 A·4 および図 A·5 に，GitHub 上で公開された PoC と，ハニーポットで観測した攻撃 HTTP リクエストの例を示す．ペイロード部分を除くと，観測された攻撃リクエストは PoC が生成するリクエストと一致しており，公開された PoC コードが実際の攻撃，あるいはマルウェアへの組み込みに悪用された可能性を示唆する．

4.3.2　攻撃のピーク

攻撃開始からピークまでの期間．攻撃開始からピークに達するまでの期間は，攻撃者による攻撃展開の速度と，防御側に求められる対応時間を把握する上で重要である．そこで，52 件のエクスプロイトについて，初回攻撃観測日から，日単位の悪用試行数が最大となった日（以下，ピーク）までの期間を分析した（付録 A.6 の図 A·8）．その結果，一部の例外を除き，多くのエクスプロイトは初回の観測後から短期間でピークに達しており，その中央値は 8 日であった．攻撃者にとっては，防御側による対策が講じられる前に攻撃および感染を拡大することが有利であるため，初回攻撃後の早い段階で攻撃規模がピークに達する傾向は，こうした攻撃戦略と整合する．一方，防御側には，脆弱性の公開後，可能な限り早期に対策を講じ，攻撃の拡大を抑制することが求められる．

マルウェアへの組み込み後の攻撃増加．94 件のエクスプロイトのうち，33 件（35.1%）についてマルウェアへの組み込みを確認した．エクスプロイトがマルウェアへ組み込まれると，感染機器から自動的かつ広範に攻撃が実行されるため，攻撃量が増加すると考えられる．52 件の分析対象のうち，マルウェアへの組み込みを確認した 12 件について調査した結果，11 件では，マルウェアへの組み込みを初めて確認した後に攻撃規模がピークに達していた．図 2 に示す CVE-2020-8515 および CVE-2021-31755 はその代表例である．また，マルウェアへの組み込みが確認されたエクスプロイトでは，ピーク時の月間攻撃セッション数の中央値が 125 件であり，組み込みが確認されなかったエクスプロイトの 21 件を上回った（付録 A.6 の図 A·9）．この結果は，マルウェアへの組み込みによって，ボットネットを構成する多数の感染機器から攻撃が実行され，攻撃規模が拡大する可能性を示唆する．

さらに，付録 A.6 の図 A·6 に，52 件の各エクスプロイトについて，ISP ネットワークおよびホスティングサービスから観測された累積攻撃数を示す．多数の攻撃元ホストから攻撃された脆弱性では，エクスプロイトがマルウェアへ組み込まれている場合が多く，ISP ネットワーク上の感染 IoT 機器が攻撃元として利用されていると考えられる．一方，マルウェアへの組み込みが確認されていないエクスプロイトであっても，ホスティングサービス上の少数のホストから大規模な攻撃が送信される事例が確認された．これらの結果は，攻撃者が，マルウェアに感染した IoT 機器を利用して攻撃規模を拡大する戦略と，自らが管理するホスティング基盤から大規模な探索および悪用を行う戦略の双方を用いていることを示唆する．また，マルウェア検体のみを対象とした既存研究 [4], [5] では捉えにくい後者の攻撃活動についても，ハニーポットによる攻撃観測を組み合わせることで把握できることを示している．

4.3.3　攻撃減少

攻撃効率の観点から，ある脆弱性の影響を受ける機器が減少すると，攻撃者にとって当該脆弱性を継続的に悪用する利点も低下すると考えられる．そこで本節では，各脆弱性に対する攻撃規模が，ピーク到達後に最終的にピーク時の 50%未満へ低下するまでの期間を「半減時間」と定義し，各ライフイベントと攻撃減少との関係を分析する．

セキュリティパッチと攻撃減少の関係．セキュリティパッチの提供状況は，攻撃の継続期間に影響を与える可能性がある．付録 A.6 の図 A·10 に示すとおり，パッチが提供されていない脆弱性では，攻撃半減時間の中央値が 20 日であったのに対し，パッチが提供された脆弱性では 1 日であった．この結果は，セキュリティパッチの提供が攻撃の早期減少と関連することを示している．一方，パッチが提供された場合でも，利用者が適用しなければ脆弱な状態は解消されず，攻撃が継続する可能性がある．したがって，パッチを迅速に提供するだけでなく，利用者による速やかな適用を促す仕組みや，ファームウェアの自動更新機能を

© 2026 Information Processing Society of Japan

導入することが重要である．

自動ファームウェア更新と攻撃減少の関係．52 件のエクスプロイトについて，対象機器が備えるファームウェア更新機能と攻撃半減時間との関係を分析した（付録 A.6 の図 A·11）．その結果，自動ファームウェア更新機能を持つ機器を標的とするエクスプロイトでは，攻撃半減時間の中央値が 2 日であったのに対し，新しいファームウェアの公開を利用者へ通知する機能のみを持つ機器では 3 日であった．また，平均値はそれぞれ 9.5 日と 40.5 日であり，通知機能のみを持つ機器では半減時間の分布の裾が長く，一部のエクスプロイトに対する攻撃が長期間継続する傾向がみられた．これらの結果は，自動更新機能や更新通知機能を備えた機器では脆弱性の修正が速やかに適用されることで攻撃可能な機器が減少し，攻撃が早期に減少する可能性を示唆する．

マルウェアへの組み込みと攻撃減少の関係．マルウェアへ組み込まれたエクスプロイトでは，攻撃が長期間継続する傾向がみられた．付録 A.6 の図 A·12 に示すとおり，マルウェアへ組み込まれたエクスプロイトでは，攻撃半減時間の中央値が 119 日，平均値が 410 日であった．一方，組み込みが確認されなかったエクスプロイトでは，中央値が 1 日，平均値が 139 日であった．特に，マルウェアへ組み込まれたエクスプロイトでは，半減時間が長期に及ぶ事例が存在し，裾の長い分布を示した．

この傾向の一因として，エクスプロイトがマルウェアへ組み込まれた後は，多数の感染機器が自律的に攻撃を継続するため，攻撃者が当該エクスプロイトの利用を停止した後も攻撃が継続する可能性が考えられる．この結果と整合して，2018 年以前に公開された脆弱性を標的とするエクスプロイトでは 57.1%（35 件中 20 件）でマルウェアへの組み込みが確認されたのに対し，2019 年以降に公開された脆弱性では 22.0%（59 件中 13 件）であった．このことは，古い脆弱性を標的とする攻撃が長期にわたり継続する要因の一つとして，マルウェアへの組み込みが関係している可能性を示唆する．

5. 考察

5.1 追加分析：NVD における脆弱性公開から初回攻撃観測までの期間の短縮傾向

本節では，国際会議論文 [1] の投稿後に取得した追加の観測データを用いて，2024 年から 2026 年に採番され，かつ我々のハニーポットにおいて悪用を観測した IoT 脆弱性を対象に，NVD における脆弱性の開示から最初の攻撃が観測されるまでの期間の傾向を分析する．

結果を表 3 に示す．第 4.3 節で分析した 52 件のエクスプロイト（CVE-2019 – CVE-2024）では中央値が 72 日であったのに対し，CVE-2024 の 29 件では 64 日，CVE-2025 の 27 件では 38 日，CVE-2026 の 3 件では-7 日となっており，近年採番された CVE-ID ほど脆弱性の公開から攻撃開始までの期間が短くなる傾向がみられた．この傾向は，脆弱性の公開後，攻撃者による攻撃コードの実装や組み込みが迅速化し，防御側が脆弱性対応に利用できる猶予時間が短縮しつつある可能性を示唆する．

表 3 近年の脆弱性における脆弱性公開から初回攻撃観測までの日数

対象	N	中央値（日）
第 4.3 節の分析対象（CVE-2019 – CVE-2024）	52	72
CVE-2024-XXXX	29	64
CVE-2025-XXXX	27	38
CVE-2026-XXXX	3	−7

ただし，本分析にはいくつかの制限がある．第一に，CVE-2026 は 3 件とサンプル数が少なく，個々の事例の影響を強く受けるため，現時点で傾向を一般化することは難しい．第二に，NVD への掲載が実際の脆弱性情報の流通よりも遅れることにより測定上の日数が実際よりも短く見える可能性がある．第三に，観測期間の終端に近い脆弱性ほど観測可能な期間が短く，今後初めて攻撃が観測される脆弱性が分析対象に含まれていない可能性がある．これらはいずれも近年の CVE-ID ほど測定日数を過小に見積もる方向に作用するため，本結果はこの影響を考慮して解釈する必要がある．

5.2 提言

以上に基づき，各ステークホルダーに対する提言を行う．

IoT 機器メーカーに対して．迅速なパッチ提供と自動ファームウェア更新は，攻撃の早期減少と関連する．メーカーは，脆弱性や PoC の公開後，速やかにパッチを提供し，自動更新を既定で有効にすべきである．また，サポート終了を明示し，対象製品の利用者に機器の交換を促すことが望ましい．

ネットワークおよびクラウドサービス事業者に対して．IoT エクスプロイトを用いた攻撃は，ISP ネットワーク上の感染機器とクラウド上のサーバの双方から送信される．事業者は，既知のエクスプロイトやマルウェアダウンロードに特徴的なトラフィックを検知し，継続的に攻撃を送信するホストを特定・隔離することが求められる．

利用者に対して．サポートが終了した機器は，セキュリティ更新が提供される機器へ交換すべきである．また，自動更新を有効にし，手動更新が必要な場合には速やかに適用すべきである．

規制・認証制度の策定者に対して．規制・認証制度は，迅速なセキュリティパッチ提供や自動更新の導入を促進すべきである．実際に米国の Cyber Trust Mark や日本の JC-STAR においても，セキュリティ更新方針の明示や適時の更新を機器メーカーに求めている．

© 2026 Information Processing Society of Japan

5.3 制約

本研究は，ハニーポットによる観測データおよび公開情報に基づくため，データ収集および分析範囲に以下の制約がある．ただし，これらの制約を考慮しても，IoT エクスプロイトのライフサイクルに関する主要な傾向を明らかにする上で，本研究の分析結果は有効であると考える．

観測範囲．本研究では，HTTP ベースの攻撃を観測する HTTP ハニーポットを用い，さらに分析対象をリモートコード実行によりマルウェア感染を試みるエクスプロイトのみに限定した．この方法により，無関係なトラフィックを効果的に除外できる一方，観測対象外のプロトコルや異なる攻撃手法を用いるエクスプロイトを見落とす可能性がある．IoT 機器の WebUI や CPE WAN Management Protocol（CWMP）など HTTP を基盤とする攻撃経路は観測できる一方，本研究の結果を HTTP 以外の攻撃へ直接一般化することはできない．

PoC の収集．本研究における PoC の収集は CVE-ID を基準としており，GitHub，Exploit-DB，Packet Storm において CVE-ID が明示された公開情報を対象とした．そのため，CVE-ID が割り当てられていない脆弱性に対する PoC，CVE-ID を明示せずに公開された PoC，および本研究の収集対象外のプラットフォームや非公開環境で共有された PoC を見落としている可能性がある．このため，PoC の公開状況には一定の偽陰性が含まれ得る．一方，本研究で対象とした三つのサイトはいずれも脆弱性およびエクスプロイトに関する代表的な公開プラットフォームであり，実環境の攻撃に利用され得る公開 PoC の主要な部分を収集できていると考える．

マルウェア解析．本研究では表層解析を用いてマルウェアに組み込まれたエクスプロイトを特定しているため，強く難読化されたバイナリや暗号化・パッキングされたバイナリに含まれるエクスプロイトを見落とす可能性がある．本研究のデータセットでは，UPX ヘッダのマジックバイトを含むマルウェア検体は全体の 7.65%であった．したがって，少なくとも UPX でパッキングされた検体を解析できないことによる影響は限定的と考えられる．

6. 結論

本研究では，ハニーポット観測，マルウェア解析，公開脆弱性情報を統合し，IoT エクスプロイトのライフサイクルを分析した．その結果，脆弱性の年代によって攻撃傾向が異なること，PoC 公開やマルウェアへの組み込みが攻撃の開始・拡大・長期化に関係する一方，セキュリティパッチや自動ファームウェア更新が攻撃の早期減少と関連することを明らかにした．さらに，近年は脆弱性開示から攻撃開始までの期間が短縮傾向にあることを確認し，迅速な脆弱性対応の重要性が高まっていることを示した．

謝辞 本研究は，国立研究開発法人情報通信研究機構 (NICT) の委託研究（JPJ012368C08101）により得られた成果を含む．本研究の一部は JSPS 科研費 21KK0178 の助成を受けて行われた．

参考文献

[1] Ryu Kuki, Takayuki Sasaki, Arwa Al Alsadi, Carlos Gañán, and Katsunari Yoshioka. The end of anarchy? understanding the life of http exploits used in iot malware infections. ASIA CCS '26, p. 128–143, New York, NY, USA, 2026. Association for Computing Machinery.

[2] Omar Alrawi, Charles Lever, Kevin Valakuzhy, Ryan Court, Kevin Snow, Fabian Monrose, and Manos Antonakakis. The circle of life: A Large-Scale study of the IoT malware lifecycle. In *30th USENIX Security Symposium (USENIX Security 21)*, pp. 3505–3522, August 2021.

[3] Hongda Li, Qiqing Huang, Fei Ding, Hongxin Hu, Long Cheng, Guofei Gu, and Ziming Zhao. Understanding and detecting remote infection on linux-based iot devices. In *Proceedings of the 2022 ACM on Asia Conference on Computer and Communications Security*, ASIA CCS '22, p. 873–887, 2022.

[4] Arwa Abdulkarim Al Alsadi, Kaichi Sameshima, Jakob Bleier, Katsunari Yoshioka, Martina Lindorfer, Michel van Eeten, and Carlos H. Gañán. No spring chicken: Quantifying the lifespan of exploits in iot malware using static and dynamic analysis. In *Proceedings of the 2022 ACM on Asia Conference on Computer and Communications Security*, ASIA CCS '22, p. 309–321, 2022.

[5] Arwa Abdulkarim Al Alsadi, Kaichi Sameshima, Katsunari Yoshioka, Michel Van Eeten, and Carlos Hernandez Ganan. Bin there, target that: Analyzing the target selection of iot vulnerabilities in malware binaries. In *RAID*, 2023.

[6] Sandra Rivera Perez, Michel Van Eeten, and Carlos H. Ganan. Patchy Performance? Uncovering the Vulnerability Management Practices of IoT-Centric Vendors . In *2024 IEEE Symposium on Security and Privacy (SP)*, pp. 1198–1216. IEEE Computer Society, May 2024.

[7] Asuka Nakajima, Takuya Watanabe, Eitaro Shioji, Mitsuaki Akiyama, and Maverick Woo. A pilot study on consumer iot device vulnerability disclosure and patch release in japan and the united states. In *Proceedings of the 2019 ACM Asia Conference on Computer and Communications Security*, Asia CCS '19, p. 485–492. Association for Computing Machinery, 2019.

[8] Seiya Kato, Rui Tanabe, Katsunari Yoshioka, and Tsutomu Matsumoto. Adaptive observation of emerging cyber attacks targeting various iot devices. In *2021 IFIP/IEEE International Symposium on Integrated Network Management (IM)*, pp. 143–151, 2021.

[9] James C Davis, Sophie Chen, Huiyun Peng, Paschal C Amusuo, and Kelechi G Kalu. A guide to stakeholder analysis for cybersecurity researchers, 2025.

[10] Xuan Feng, Qiang Li, Haining Wang, and Limin Sun. Acquisitional rule-based engine for discovering Internet-of-Things devices. In *27th USENIX Security Symposium (USENIX Security 18)*, pp. 327–341, Baltimore, MD, August 2018. USENIX Association.

[11] CVE-2020-8515-PoC. `https://github.com/imjdl/CVE-2020-8515-PoC`, Online. This work is distributed in the Apache License 2.0. (`https://www.apache.org/licenses/LICENSE-2.0`).

© 2026 Information Processing Society of Japan

研究倫理

本研究は，インターネット上に設置した HTTP ハニーポットで観測した攻撃通信，収集したマルウェア検体，ならびに公開されている脆弱性，PoC，セキュリティパッチ等の情報を統合し，IoT エクスプロイトのライフサイクルを分析するものである．このような研究は，実環境における攻撃の開始，拡大，減少の実態を把握し，パッチ提供や自動ファームウェア更新等の対策と攻撃減少との関連を評価する上で有用である一方，ハニーポットの悪用，観測した通信に含まれる情報の取り扱い，研究成果やデータの攻撃への転用，未公開脆弱性の不適切な開示，特定のメーカーやサービス事業者への不利益，ならびに観測結果の過度な一般化といった倫理的リスクを伴う．特に，ハニーポットへ攻撃通信を送信するホストは，攻撃者が直接管理する機器だけでなく，既にマルウェアへ感染した第三者の IoT 機器である可能性があるため，観測された送信元を一律に攻撃主体として扱うことは適切でない．

そこで本研究では，Menlo Report の基本原則および Stakeholder-Based Ethics Analysis [9] の枠組みに基づき，本研究によって影響を受け得るステークホルダーごとの便益とリスクを整理し，それらを低減するための緩和策を検討した．

ステークホルダーと便益・リスク

ハニーポットの設置機関およびクラウドサービス事業者．

ハニーポットによる継続的な攻撃観測は，実サイバー空間上の攻撃動向を把握し，攻撃の早期検知や対策につながる知見を得ることを可能にする．一方，ハニーポットの実装や設定に不備があり，第三者への攻撃やマルウェア配布の踏み台として悪用された場合，設置機関，クラウド事業者および第三者に被害を与える可能性がある（**R1**）．また，収集したマルウェアを研究環境内で不用意に実行した場合にも，同様に外部へ影響を及ぼす可能性がある．

攻撃元機器の所有者およびネットワーク利用者．

攻撃元に関する分析によって，感染 IoT 機器が存在する ISP ネットワークと，攻撃者が利用するホスティング基盤の双方が攻撃に関与している実態を把握できることは，ISP やクラウド事業者による対策の検討に資する．一方，本研究では攻撃元 IP アドレスを観測するため，IP アドレスや通信内容を他の情報と組み合わせることで，特定の利用者，機器または組織が推定される可能性がある（**R2**）．さらに，送信元がマルウェアに感染した第三者機器である場合，その所有者自身は攻撃を意図していない可能性があり，観測された IP アドレスを攻撃者そのものとして公表または評価することは，不適切な帰属や風評被害につながり得る（**R2**）．

IoT 機器の利用者およびインターネット上の第三者．

本研究によって，PoC 公開後には短期間で攻撃が開始され得ること，マルウェアへの組み込みによって攻撃が大規模化・長期化し得ること，ならびにセキュリティパッチや自動ファームウェア更新が攻撃の早期減少と関連することを明らかにすることは，利用者が適切な更新や機器交換を行うための根拠となる．また，IoT 機器がボットネットへ組み込まれた場合には，所有者本人だけでなく，DDoS 攻撃やさらなる感染活動を通じて第三者にも被害が及ぶため，攻撃を抑制するための知見には広い社会的便益がある．一方，エクスプロイトの利用時期，攻撃規模，PoC との対応関係，マルウェアへの組み込み状況，攻撃 HTTP リクエスト等を詳細に公開すると，既存の攻撃を再現または効率化する情報として利用される可能性がある（**R3**）．

IoT 機器メーカーおよび脆弱性対応に関与する組織．

実際の攻撃観測に基づいて，パッチ提供や自動ファームウェア更新と攻撃継続期間との関係を評価することは，メーカーが脆弱性対応や製品の更新機構を改善する際の根拠となる．また，新たな脆弱性や既知脆弱性の悪用開始を CERT 等へ共有することで，利用者への注意喚起や修正の促進につながる．一方，未修正の脆弱性について攻撃可能な情報を公開した場合，メーカーが対策を提供する前に実環境での悪用を促進する可能性がある（**R4**）．また，本研究の結果が特定のメーカーまたは製品のセキュリティ品質に対する評価として単純化された場合，メーカーに不必要な評判上または経済的な不利益を与える可能性がある（**R5**）．

セキュリティ実務者，研究者，CERT，ネットワーク事業者および制度策定者．

IoT エクスプロイトの攻撃開始から減少までを実測し，PoC 公開，マルウェアへの組み込み，パッチ公開，自動ファームウェア更新といったライフイベントとの関係を明らかにすることは，脆弱性開示後の対応優先度の決定，ネットワーク上での攻撃検知，製品セキュリティ要件や認証制度の検討に有用である．一方，本研究の観測範囲は HTTP ベースの攻撃，特定の RCE パターン，配置したハニーポット群，収集可能であった PoC およびマルウェア検体に限定される．したがって，本研究における「初回攻撃観測」はインターネット全体における最初の悪用を意味するものではなく，パッチ提供や自動更新と攻撃減少との関連についても，本研究の観測のみから一意の因果関係を確定できるものではない．これらの制約を考慮せず，研究結果を製品評価，規制，脆弱性開示方針等へ直接一般化した場合，不適切な意思決定につながる可能性がある（**R6**）．

リスクを低減するための緩和策

R1：ハニーポットおよび研究基盤の悪用．

本研究で用いたハニーポットは，攻撃者が送信したコマンドやマルウェアをハニーポット上で実行せず，攻撃の踏

© 2026 Information Processing Society of Japan

み台として利用できないように構成した．マルウェア検体についても，ハニーポット上で実行するのではなく，文字列等の観測可能な情報を抽出する表層解析を中心としてエクスプロイトの組み込み状況を分析した．これにより，研究のために設置したシステム自体が新たな攻撃主体となる可能性を低減した．

R2：攻撃元情報に関するプライバシーおよび不適切な帰属．

攻撃元 IP アドレスは，攻撃元が ISP またはホスティングサービスのいずれに属するかを分類し，攻撃傾向を集計する目的で利用した．研究成果の公表では，個々の IP アドレスやその所有者を攻撃主体として特定するのではなく，ISP，ホスティングサービス，攻撃元ホスト数等の集計情報を用いる．また，ISP ネットワークから観測された通信にはマルウェアへ感染した第三者機器から送信されたものが含まれ得ることを前提とし，観測された送信元 IP アドレスを攻撃者本人と同一視しない．これにより，研究成果を通じた個人・組織の推定や，不適切な攻撃主体の帰属による不利益を低減する．

R3：研究成果および研究データの攻撃への転用．

本稿では，エクスプロイトのライフサイクルを理解するために必要な時系列，攻撃規模およびライフイベントの関係を中心に報告し，新たな攻撃を可能にすること自体を目的とした手順や未公開の攻撃コードは提供しない．攻撃リクエストの例を示す場合には，既に公開されている PoC との対応関係を示すために必要な範囲に限定し，実際のマルウェア配布先等，現時点の攻撃活動へ直接接続し得る情報を秘匿する．

また，Open Science の観点から再現可能性を確保する一方，攻撃 HTTP リクエストおよびマルウェア検体は，そのまま公開すると攻撃へ転用され得るため，不特定多数が直接取得可能な形では提供せず，研究者からの個別の申請に基づいて共有する．さらに，国の輸出管理リスト等を考慮し，提供先によっては共有を行わない場合がある．一方，エクスプロイトのタグ付けルール，公開脆弱性情報への参照，機器マニュアルへの参照，分析スクリプト等については，攻撃そのものの実行能力を不必要に高めない範囲で共有することで，再現性と安全性の両立を図る．

R4：未修正脆弱性の開示による悪用促進．

ハニーポット観測を通じて未知の脆弱性を発見した場合には，攻撃可能な詳細を直ちに公開せず，適切な調整機関を介してメーカーへ通知する責任ある開示を行う．実際に，本研究の観測を通じて発見したゼロデイ脆弱性については JPCERT/CC を通じて開発者へ報告し，開発者による修正を経て CVE-2023-49897 が発行された．また，既知の脆弱性について実環境での悪用開始を確認した際にも，国内 CERT と情報を共有した．本稿では，このような調整を経た脆弱性について研究上必要な事実を報告することで，研究成果の公表が未修正脆弱性の悪用を先行して促進しないよう配慮した．

R5：機器メーカー・サービス事業者への不利益および研究結果の誤解．

本研究では，脆弱性，パッチ，自動更新機能等の情報を，NVD，機器メーカーのセキュリティアドバイザリ，機器マニュアル等の公開情報に基づいて整理した．分析の目的は，特定のメーカーや製品を順位付けして評価することではなく，脆弱性の年代，パッチ提供，更新機構等と攻撃ライフサイクルとの関係を明らかにすることである．そのため，本稿では個別事例を必要以上に一般化せず，特定のメーカーについて「安全」または「危険」とする評価を行わない．また，古い製品に対する長期的な攻撃が観測されたことのみを根拠として，メーカーの対応不足や利用者の過失を推定しない．

R6：研究結果の過度な一般化および不適切な政策利用．

本稿では，HTTP ハニーポットによる観測範囲，`wget` や `curl` 等を含む RCE 攻撃へ分析対象を限定したこと，PoC の収集先が GitHub，Exploit-DB，Packet Storm 等に限定されること，マルウェアの表層解析では難読化されたエクスプロイトを見落とす可能性があること，ならびに観測期間およびハニーポット配置による可視性の制約を明示する．特に，本稿で定義する攻撃開始は我々のハニーポットにおける初観測時点であり，実環境全体で最初に悪用された時点と同一ではない．また，パッチ，自動ファームウェア更新，マルウェアへの組み込みと攻撃減少速度との関係は観測された関連として解釈し，本研究だけから個々の要因の因果効果を過度に断定しない．2025 年および 2026 年に公開された脆弱性について確認した攻撃開始の早期化についても，本研究の観測範囲における傾向として報告する．

したがって，本研究の結果を，個別製品の安全性評価，特定製品の利用禁止，一律のサポート期間の設定等の単独の根拠として用いることは想定しない．本研究が示す実測結果を，他の実証研究，脆弱性情報，製品特性等と併せて利用することを前提とする．

公表の妥当性

本研究には，攻撃のライフサイクルや PoC と実攻撃との関係を公表することで，攻撃者が攻撃対象や時期を検討する際の参考情報として利用する可能性（**R3**），観測された IP アドレスや製品情報から特定の利用者・組織・機器メーカーが不適切に評価される可能性（**R2，R5**），ならびに限定された観測結果が製品評価や制度設計へ過度に一般化される可能性（**R6**）が残る．これらのリスクを完全に除去することはできない．

一方，本研究は，新たな脆弱性の悪用方法を提示することではなく，実環境で既に発生している攻撃を長期間観測することにより，脆弱性の開示後に攻撃がどの程度の速さで

© 2026 Information Processing Society of Japan

開始・拡大するか，マルウェアへの組み込みによって攻撃がどの程度長期化するか，さらにパッチ提供や自動ファームウェア更新が攻撃の減少とどのように関係するかを明らかにするものである．これらの知見は，機器メーカーによる迅速なパッチ提供と自動更新機構の導入，CERT による早期警戒，ISP およびクラウド事業者による攻撃トラフィックへの対応，ならびに脆弱性開示後の防御側の優先順位付けを改善するための実証的根拠となる．特に，PoC 公開後の短期間に攻撃が開始され得ることや，近年の脆弱性では公開から初観測までの期間が短縮する傾向を明らかにすることは，防御側が脆弱性公開後の対応時間を再検討する上で重要である．

以上の便益と，上述したハニーポットの安全な運用，個々の攻撃元を特定しない集計分析，攻撃に転用可能なデータの共有制限，責任ある脆弱性開示，ならびに研究の観測範囲と解釈上の制約の明示を講じた後に残るリスクを比較した．その結果，IoT 機器を標的とする攻撃の長期的な抑制と，脆弱性対応の改善に資する学術上・社会上の便益が残存リスクを上回ると判断し，本研究成果を公表することは妥当であると考える．

付　　録

A.1　Open Science

本論文で使用した以下のデータを共有する予定である．

- ハニーポットで観測された HTTP リクエストおよびマルウェア検体．これらのデータは攻撃に利用され得るため，研究者からの個別の申請に基づいて共有する．また，国の輸出管理リストに掲載された組織には提供しない場合がある．
- エクスプロイトのタグ付けルール．
- 脆弱性情報および PoC などの公開データへのリンク．
- エクスプロイトの標的となる機器のマニュアルへのリンク．
- 上記データの分析に使用したスクリプト．

A.2　エクスプロイトのライフサイクルの事例

本節では，本文で示したライフサイクルモデルと主要イベントの影響を，具体的な観測事例に即して示す．エクスプロイトは他のソフトウェアと同様に，その存続期間中に複数の段階を経る．どの段階でどのイベントが攻撃規模を左右するのかを事例に基づいて把握することは，脆弱性開示後の対応の優先順位を定める上で不可欠である．

図 A·1 に，DrayTek 製ルータの OS コマンドインジェクション脆弱性である CVE-2020-8515 を標的とする攻撃の観測結果を示す．同図は，NVD における脆弱性の開示から攻撃の開始，ピーク，減少に至るまでの時系列を，セキュリティパッチおよび PoC コードの公開，マルウェアへの組み込みといった主要なライフイベントとあわせて表したものであり，IoT エクスプロイトの典型的なライフサイクルを示している．

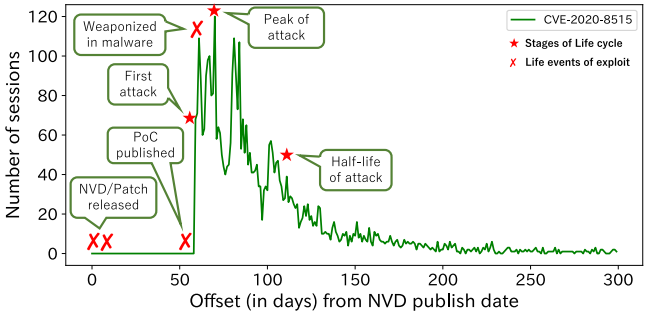


図 A·1　CVE-2020-8515 におけるエクスプロイトのライフイベントとハニーポット観測数

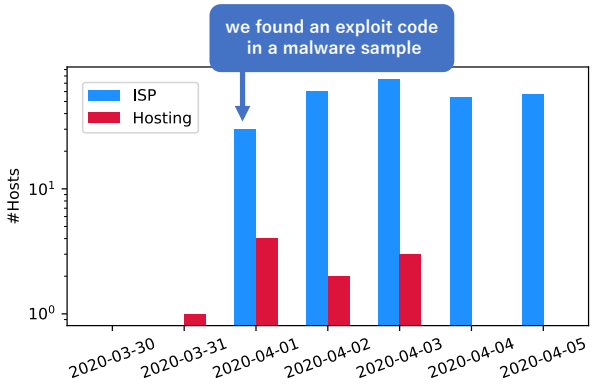


図 A·2　CVE-2020-8515 を標的とする攻撃元ホスト数

同脆弱性は 2020 年 2 月 1 日に NVD で公開され，その 5 日後の 2 月 6 日にパッチが公開された．しかし，この時点では攻撃は観測されなかった．その後 3 月 30 日（脆弱性公開から 58 日後）に GitHub で PoC コードが公開された後，その翌日（脆弱性公開から 59 日後）には初回の攻撃が観測された．さらにその翌日（脆弱性公開から 60 日後）にはマルウェアへの組み込みが確認され，感染機器からの攻撃が急増し，脆弱性公開から 70 日でピークに達した．

ピーク到達後，攻撃量は変動を伴いながら徐々に減少し，ピークから 32 日後（脆弱性公開から 102 日後）に半減した．その後はおおむね滑らかに減少し，ピークから 91 日後（脆弱性公開から 161 日後）にピーク時の 10%を下回った．この減少の速度は，攻撃の立ち上がりの速さと比べて著しく緩やかである．図 A·2 に示すとおり，ピーク後に観測された攻撃の大部分は ISP が割り当てた IP アドレスから送信されており，マルウェアに感染した IoT 機器が送信元であった可能性がある．パッチが早期に公開されていたにもかかわらず感染機器が長期にわたり残存していた可能性が，攻撃が長期化した一因として考えられる．

© 2026 Information Processing Society of Japan

A.3 データ収集とタグ付けの詳細

A.3.1 ハニーポットインスタンスの配置

本研究で採用した X-POT は，観測した攻撃に対応する IoT 機器の HTTP 応答を収集し，模倣対象を拡張する適応型 HTTP ハニーポットである [8]．大学ネットワークおよび Amazon EC2，DigitalOcean，Vultr 上の複数地域に 22 インスタンスを配置した．配置したハニーポットインスタンスの一覧を表 A·1 に示す．

表 A·1 配置したハニーポットインスタンス一覧

配置先	国・地域コード	IP 数
AWS	AU,BH,BR,DE,HK,IE,IN,JP,KR,SE,SG,US	12
DigitalOcean	IN,NL,SG	3
Vultr	CA,FR,GB,JP,SG	5
大学ネットワーク	JP,VN	2
合計		22

A.3.2 攻撃トラフィックのタグ付け処理の詳細

タグ付けルールの構成．各タグ付けルールは，以下のフィールドから構成される．(1) `Signature`：特定の攻撃パターンを表す文字列シグネチャ（例：HTTP パス，パラメータ名，特徴的なペイロード断片），(2) `Exploit tag`：CVE-ID または対象機器名などのエクスプロイト識別子，(3) `Reference`：Exploit-DB，NVD，関連アドバイザリなどのエクスプロイト情報源への参照，(4) `Device type`：エクスプロイトが IoT 機器または非 IoT 機器のいずれを標的とするか，(5) `IoT type`：IoT エクスプロイトについて，影響を受ける機器の具体的なカテゴリ．本研究で観測した IoT エクスプロイトのうち約半数はルータの脆弱性を標的としており，残りを先行研究 [2], [10] の分類に従い IP カメラ，NAS，NVR，DVR など 26 種類の機器種別に分類した．

タグ付けルールは YAML 形式で記述する．タグ付けルールの作成例を図 A·3 に示す．このルールに一致する攻撃には `CVE-2017-6334` を付与する．このエクスプロイトに固有の HTTP リクエストパス `/dnslookup.cgi` とフィールド名 `host_name` を，攻撃識別用のシグネチャとして用いる．この攻撃の標的は IoT 機器であり，具体的にはルータである．

```
- signature:
 - /dnslookup.cgi
 - host_name
 memo: https://www.exploit-db.com/exploits/42257
 tag: CVE-2017-6334
 device_type: iot
 iot_type: router
```

図 A·3 CVE-2017-6334 のタグ付けルール

新規ルールの生成．既存ルールのいずれにも一致しない新たな攻撃を観測した場合，以下のパイプラインで新規ルールを作成する．特徴文字列の抽出と脆弱性データベースの初期検索は自動化し，その後の確認とルール作成は手動で実施する．

(1) **特徴文字列の抽出．**観測したエクスプロイトの HTTP リクエストから，HTTP パスおよびペイロードを格納するフィールド名などの特徴文字列を抽出する．この処理は，`curl`，`wget`，エンコードされたペイロードなど一般的なエクスプロイト指標を捉える正規表現とヒューリスティクスを用いて自動化する．

(2) **脆弱性データベースの検索．**抽出した文字列をキーワードとして，NVD，CNVD，Vulners，Exploit-DB などの脆弱性情報データベースを自動検索する．結果が不十分または曖昧な場合，Web 検索，ベンダアドバイザリ，セキュリティブログなどを手動で検索して補完する．

(3) **CVE および標的の確認とルール作成．**エクスプロイトを特定できた場合，関連する CVE-ID と攻撃対象（IoT 機器または非 IoT 機器，機器種別）を手動で確認し，その情報に基づいて新たなタグ付けルールを作成する．

CVE-ID との対応付けの判断規則．CVE-ID との対応付けの正確性と一貫性を高めるため，ルールへ CVE タグを付与する際に以下の判断規則を用いる．(i) 一つの CVE が複数の対象パスに対応する場合，各パターンについて個別のルールを作成し，すべてに同一の CVE を付与する．(ii) 複数の CVE が同一パスを共有する場合，パラメータ名，フィールド名，値のパターンなど識別可能な条件を追加して別個のルールへ分離する．(iii) 連鎖的または同時に悪用される CVE など曖昧性を解消できない場合，カンマ区切りの複数 CVE タグを一つのルールへ関連付ける．

相互検証，遡及適用，人手による確認．すべてのルールは，それぞれ 5 年および 20 年の経験を持つ 2 名のセキュリティ研究者が適用前に相互確認する．判断が一致しない場合，HTTP リクエスト，ペイロード，参照した外部情報源を手動で再分析して解決する．作成したルールは，ルール作成後に収集したデータだけでなく，それ以前に収集したすべての攻撃データへ遡及的に適用し，データセット全体へ一貫したラベルを付与する．最後に，タグ付け済みデータの標本を手動で確認し，付与されたタグが対応するエクスプロイトを正しく表していることを検証する．誤りや曖昧さを含むルールを確認した場合，タグ付けルールおよびシグネチャを修正して再適用し，タグ付け精度を改善する．

A.4 公開脆弱性・エクスプロイト情報の収集の詳細

本付録では，第 3.2 節で概説した公開脆弱性・エクスプ

© 2026 Information Processing Society of Japan

ロイト情報の情報源ごとの収集結果の詳細を述べる．これらの情報は，ハニーポットデータを分析した 2024 年 8 月 14 日に取得した．

脆弱性情報．

NVD からは，計 261,858 件の CVE-ID と，説明，公開日，CVSS スコア，参照情報，CWE-ID などの脆弱性情報を収集した．CNVD からは，116,405 件の CNVD-ID と，説明，公開日，脆弱性種別，参照情報などを収集した．Vulners については，API を介してデータベースを検索し，脆弱性情報およびエクスプロイトコードを収集した．

セキュリティパッチ情報．

製品ベンダまたは第三者が公開したセキュリティアドバイザリから，パッチの提供有無と公開日を手動で収集した．具体的には，観測したエクスプロイトが標的とする機器メーカーの Web サイトを確認し，さらに Tenable や Rapid7 などのセキュリティ企業がアドバイザリを公開しているかを確認した結果，86 件のセキュリティアドバイザリを収集した．また，各エクスプロイトの影響対象機種についてメーカーの公式 Web サイトからユーザーマニュアルを収集し（既に入手できない場合を除く），自動ファームウェア更新などのセキュリティ対策の有無を判断した．

公開エクスプロイト（PoC）．

Exploit-DB については，公式 GitLab リポジトリをクローンし，46,104 件のエクスプロイトコードと CVE-ID および公開日を含むメタデータを収集した．GitHub については，「CVE」をキーワードとして検索し，タイトルまたは説明に CVE-ID を含む 14,323 件のリポジトリとその公開日を収集した．Packet Storm については，50,581 件のエクスプロイトコードと CVE-ID および公開日を含むメタデータを収集した．三つの情報源における CVE-ID 単位の照合結果を用い，各脆弱性について PoC が公開されているかを判定し，公開されている場合は該当する PoC の中で最も早い公開日を記録した．

IP アドレス情報．

ハニーポットで観測した攻撃元 IP アドレスがホスティングサービスまたは ISP のいずれに属するかを判定するため，IP アドレス所有者の組織情報を提供する IPinfo を利用した．

A.5　PoC コードと攻撃リクエストの例

図 A·4 および図 A·5 に，GitHub 上で公開された CVE-2020-8515 の PoC コードと，その後にハニーポットで観測された攻撃 HTTP リクエストの例を示す．

A.6　ライフサイクル分析に関する補足図

本節では，第 4.3 節で述べたライフサイクル分析の各結果について，測定値の分布を示す図を掲載する．

図 A·7 は，PoC 公開から初回攻撃観測までの日数の分布

```
def run_cmd(self, cmd):
  try:
    headers = {
      "UserAgent": "Mozilla/5.0␣(Windows␣NT␣10.0;␣Win64;
          ␣x64;␣rv:75.0)␣Gecko/20100101␣Firefox/75.0"
    }
    url = self.url + "/cgi-bin/mainfunction.cgi"
    data = "action=login&keyPath=
␣␣␣␣res␣=␣req.post(url=url,␣data=data,␣timeout=(10,␣15)
    ,␣headers=headers)
␣␣␣␣if␣res.status_code␣==␣200:
␣␣␣␣␣␣return␣res.text
␣␣␣␣else:
␣␣␣␣␣␣return␣""
␣␣except␣Exception␣as␣e:
␣␣␣␣return␣""
```

図 A·4　GitHub で公開された PoC（CVE-2020-8515）[11]

```
POST /cgi-bin/mainfunction.cgi HTTP/1.1
User-Agent: XTC
Host: 127.0.0.1
Content-Length: 1000
Accept-Encoding: gzip, deflate
Accept-Language: en-US,en;q=0.9

action=login&keyPath=‘/bin/sh –c ’wget http://XXX.XX.XX.XX/YYYY -O
/tmp/upnp.debug; chmod 777 /tmp/upnp.debug; /tmp/upnp.debug”
&loginUser=a&loginPwd=a    Malware Download & Execution Cmd
```

図 A·5　ハニーポットで観測した攻撃リクエスト（CVE-2020-8515）

を示す（第 4.3.1 節）．図 A·8 は，初回攻撃観測から攻撃のピークまでの日数の分布を示す（第 4.3.2 節）．図 A·9 は，マルウェアへの組み込みの有無別に，ピーク時の攻撃セッション数の分布を示す（第 4.3.2 節）．図 A·6 は，52 件の各エクスプロイトについて，ISP ネットワークおよびホスティングサービスからの累積攻撃数を示す（第 4.3.2 節）．なお，同図の CVE-2020-15348 および CVE-2020-35665 のように，マルウェアへの組み込みが確認されないにもかかわらず攻撃元ホスト数が多い少数の例外も存在する．これらは，他のエクスプロイトによって既に侵害されていたボットネット，または本研究のハニーポットの観測範囲の限界を反映している可能性がある．図 A·10，図 A·11，および図 A·12 は，それぞれセキュリティパッチの提供，自動ファームウェア更新機能の有無，マルウェアへの組み込みの有無別に，攻撃規模の半減時間の分布を示す（第 4.3.3 節）．

© 2026 Information Processing Society of Japan

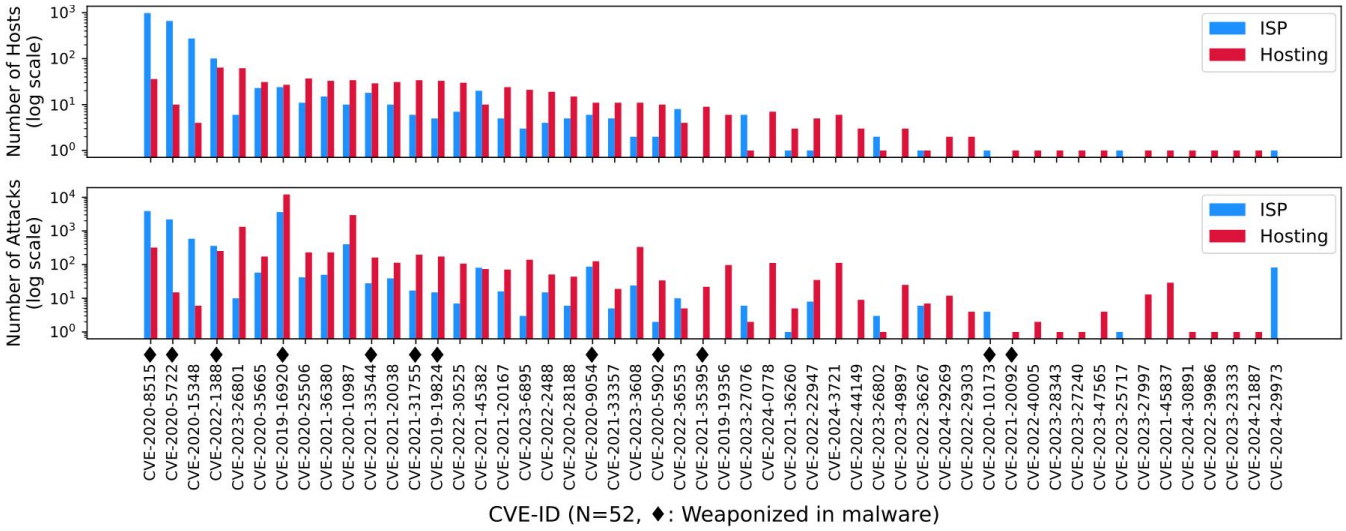


図 A·6 エクスプロイトごとの攻撃元ホスト数および累計攻撃観測数

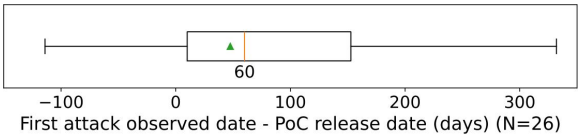


図 A·7 PoC 公開から初回攻撃観測までの日数

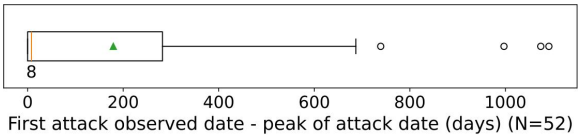


図 A·8 初回攻撃観測から攻撃のピークまでの日数

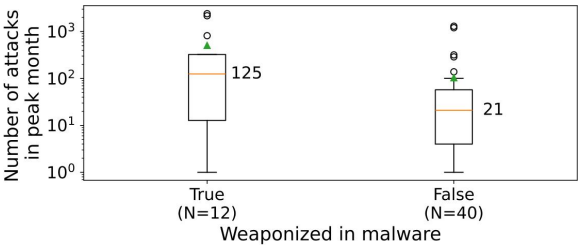


図 A·9 マルウェアへの組み込みの有無とピーク時攻撃規模の関係

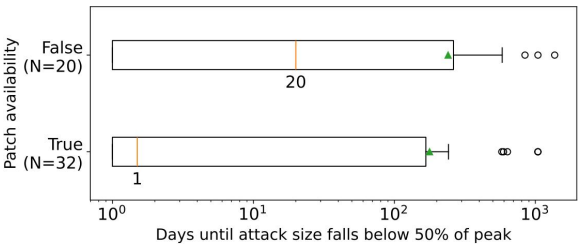


図 A·10 セキュリティパッチの有無と攻撃規模の半減時間との関係

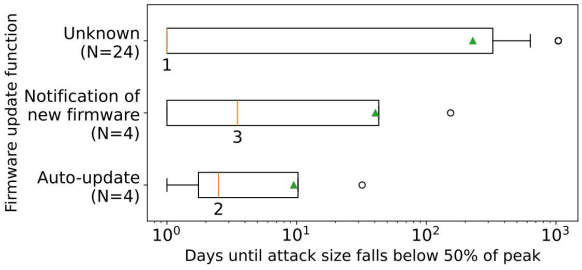


図 A·11 ファームウェア自動更新機能の有無と攻撃規模の半減時間との関係

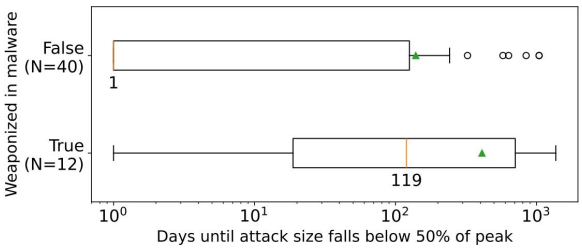


図 A·12 マルウェアへの組み込みの有無と攻撃規模の半減時間との関係

© 2026 Information Processing Society of Japan